

API SECURITY RISK ANALYSIS REPORT

(TASK – 3 | API SECURITY ASSESSMENT)

Prepared By: Rishikesh Borse

Domain: Cyber Security Intern

Internship Program: Future Interns

Track Code: CS

PROJECT OVERVIEW

This project focuses on analysing the security posture of a public demo API using structured API security testing techniques.

TARGET API USED FOR TESTING

<https://jsonplaceholder.typicode.com/users>

-
- Analyse authentication & authorization controls
- Detect potential data exposure risks
- Evaluate rate limiting implementation
- Assess input validation behaviour
- Provide business-focused remediation guidance

Tools Used

POSTMAN:- PURPOSE:

- Send HTTP requests (GET)
- Inspect API responses
- Modify endpoint parameters
- Test authentication behaviour
- Perform repeated request testing

🔍BROWSER DEVELOPER TOOLS:- PURPOSE:

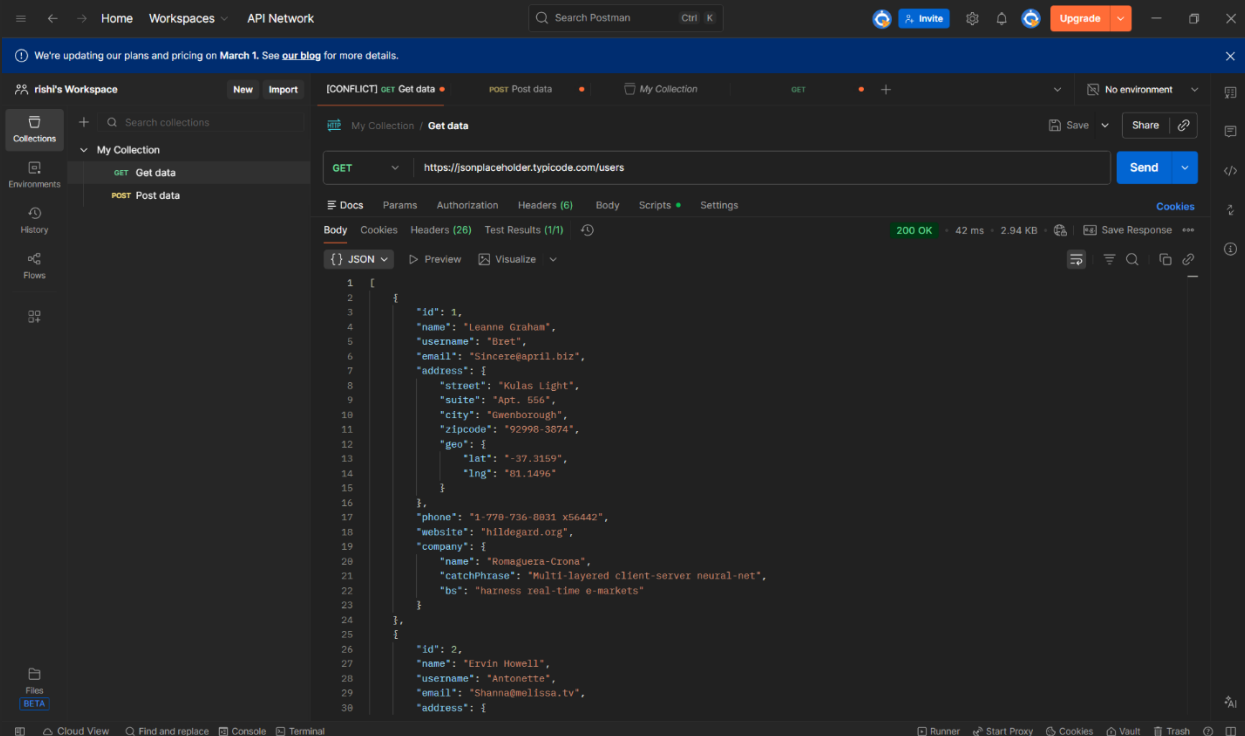
- Observe API structure
- Understand request-response format
- Analyse headers and response codes

RISK 1: MISSING AUTHENTICATION ON API ENDPOINT

Observation :- /users

Allowed access without:

- Login
- API key
- Token
- Authorization header
- Any user can directly access the API and retrieve user data.



REVIEW API DOCUMENTATION

The API provides sample user data including:

- Name
- Email
- Address
- Phone
- Company details

No authentication requirements mentioned

Business Impact

If this were a real company API:

- Unauthorized users could access customer data
- Data privacy violations may occur
- Regulatory compliance issues may arise
- Reputational damage possible

INSPECTION PERFORMED

Authentication Requirements

- No API key required
- No Bearer token
- No session validation

Headers

- Standard response headers
- No strong security headers observed

IDENTIFIED SECURITY RISKS

Open or unauthenticated endpoint
Excessive data exposure
Weak authentication controls

RISK SEVERITY CLASSIFICATION

HIGH

SUGGESTED REMEDIATION

- Implement JWT authentication
- Require API keys
- Restrict endpoint access
- Return only necessary fields

API ANALYSIS – INDIVIDUAL USER ACCESS (IDOR TEST)

ENDPOINT: `/USERS/{ID}`

SELECT DEMO API

Tested endpoints:

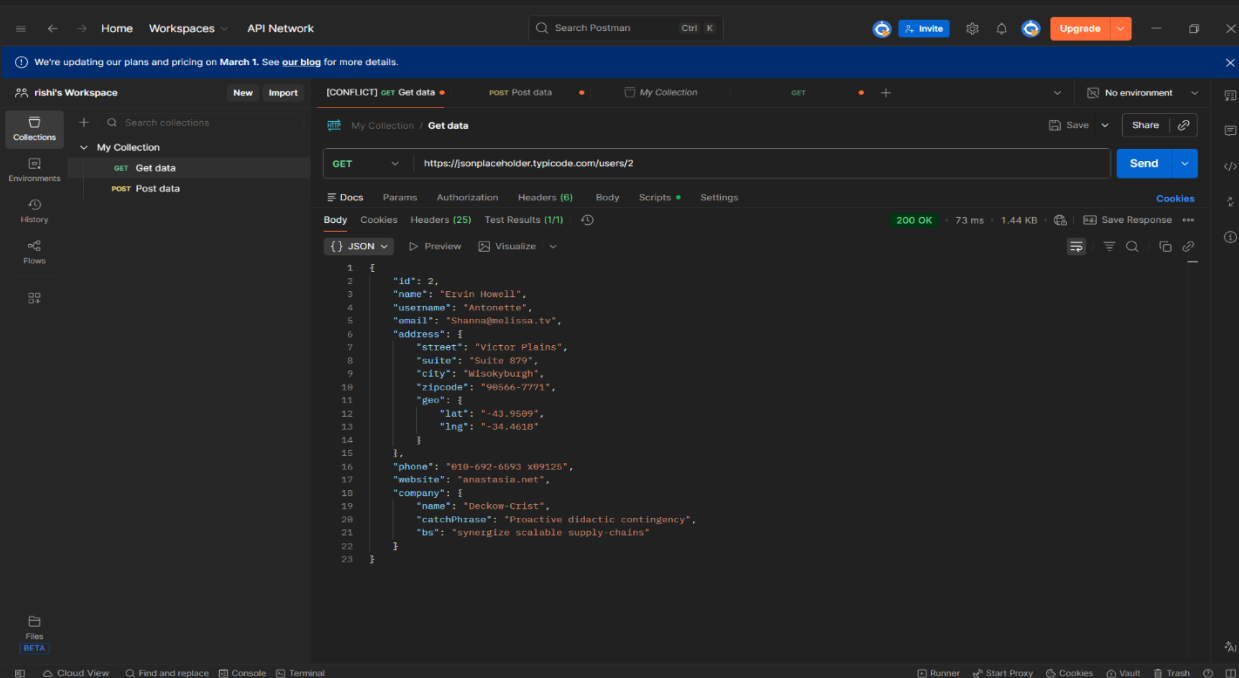
`/users/1`

`/users/2`

TEST ENDPOINT USING POSTMAN

Changed ID parameter manually.

Each ID returned different user data.



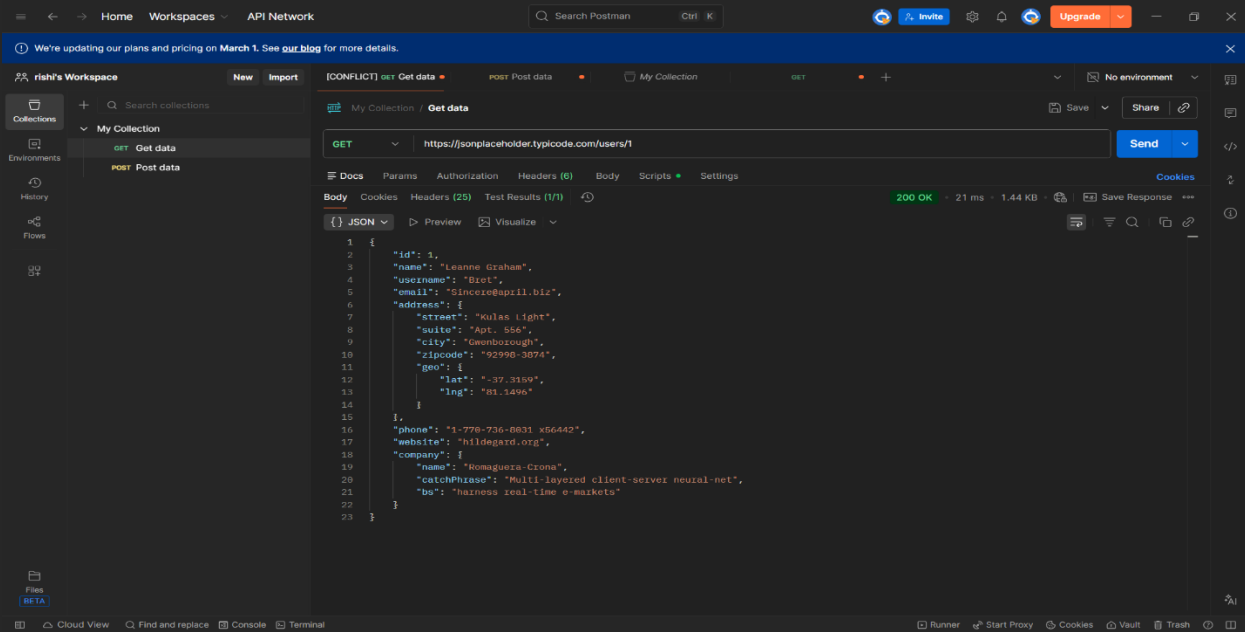
REVIEW DOCUMENTATION

Users are identified by numeric IDs.

No ownership validation documented.

RISK SEVERITY CLASSIFICATION

High (Production Scenario)



INSPECTION PERFORMED

Authentication Requirements

No authentication required.

Headers

Standard headers only.

Response Data

Full user object returned for each ID.

IDENTIFIED SECURITY RISKS

Authorization issues

Accessing other users' data

Predictable sequential IDs

Missing ownership validation

SUGGESTED REMEDIATION

- Implement Role-Based Access Control (RBAC)
- Validate user ownership before returning data
- Avoid predictable ID exposure
- Use UUIDs instead of sequential IDs

DOCUMENTATION SUMMARY

Changing numeric IDs directly exposes different user data.
In real systems, this represents an Insecure Direct Object Reference (IDOR) vulnerability.

RISK SEVERITY CLASSIFICATION

 High (Production Scenario)

API ANALYSIS –RATE LIMITING & INPUT VALIDATION TEST

SELECT DEMO API

Endpoint tested:

/users

REVIEW DOCUMENTATION

No mention of rate limiting or request throttling policies.

TEST ENDPOINT USING POSTMAN

Multiple rapid requests sent.

Malformed query parameters tested.

INSPECTION PERFORMED

Authentication Requirements

None required.

Headers

No rate-limit headers observed.

Response Data

API responded normally even after repeated requests.

IDENTIFIED SECURITY RISKS

Missing rate limiting
Input validation weaknesses
API abuse potential
Brute-force risk

RISK SEVERITY CLASSIFICATION

Medium

SUGGESTED REMEDIATION

- Implement rate limiting
- Apply request throttling
- Validate and sanitize input parameters
- Reject malformed queries

DOCUMENTATION SUMMARY

The API did not enforce request limits or strict input validation.

In production environments, this could enable API abuse, scraping, or denial-of-service attacks.

BROWSER TOOL ANALYSIS – USER LISTING ENDPOINT

ENDPOINT:

/USERS

SELECT A DEMO/PUBLIC API

Selected public demo API:

<https://jsonplaceholder.typicode.com/users>

REVIEW API DOCUMENTATION

Reviewed structure of response data:

- ID
- Name
- Email
- Address
- Phone
- Company

TEST ENDPOINT USING BROWSER

- Opened API in browser
- Pressed F12
- Opened **Network Tab**
- Refreshed page
- Observed API request

INSPECT (BROWSER-LEVEL ANALYSIS)

Authentication Requirements

No authentication headers present.
No Authorization token required.

Headers

Standard response headers observed.
No advanced security headers detected.

IDENTIFIED SECURITY RISKS

Open or unauthenticated endpoint
Excessive data exposure
Sensitive fields exposed

RISK SEVERITY

Medium

SUGGESTED REMEDIATION

- Enforce token-based authentication
- Implement access control policies
- Restrict returned data fields

DOCUMENTATION SUMMARY

Browser inspection confirmed unrestricted access to user data without authentication, which would be high risk in production systems.

